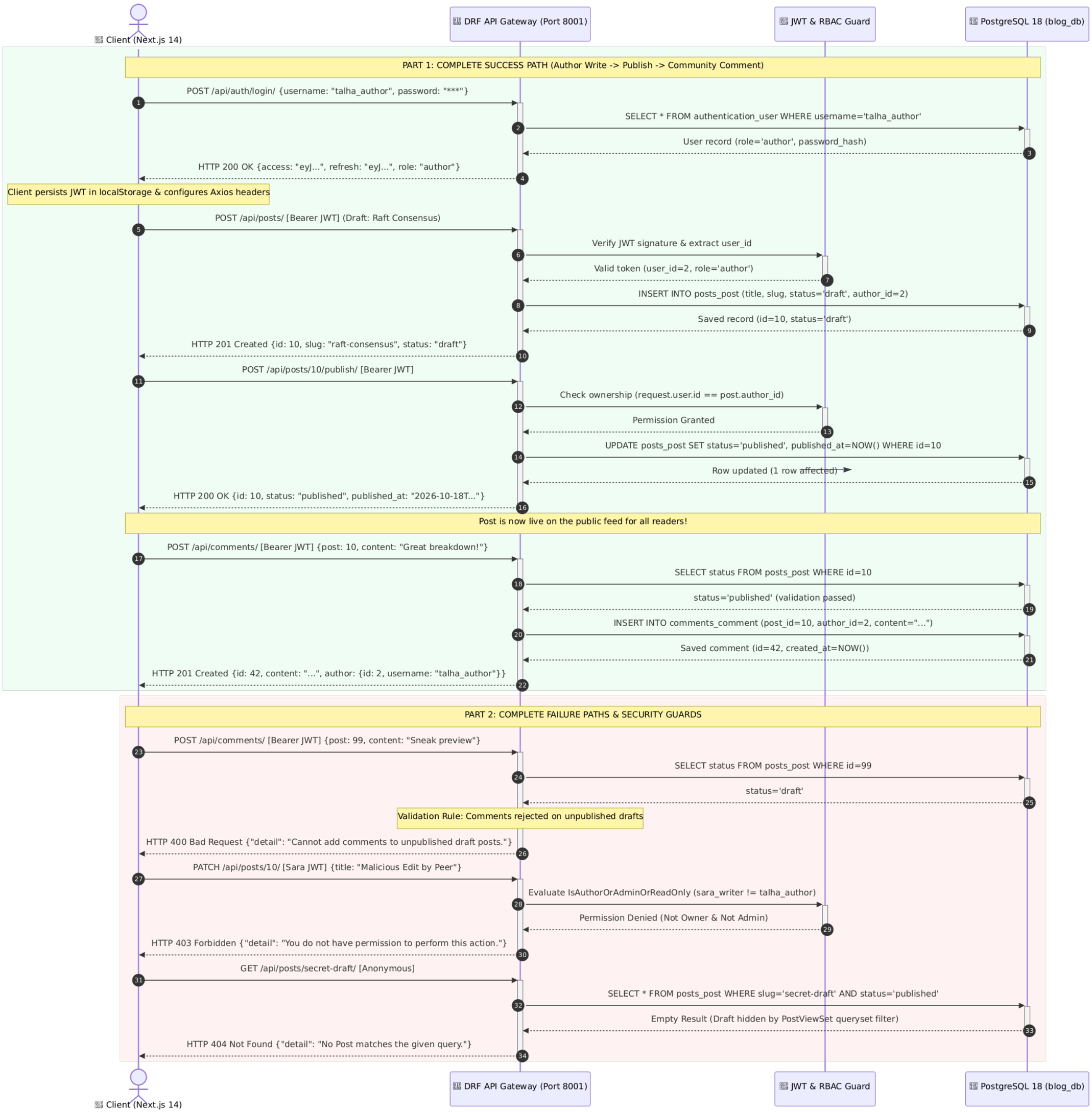

Client (Next.js 14)
DRF API Gateway (Port 8001)
JWT & RBAC Guard
PostgreSQL 18 (blog_db)
PART 1: COMPLETE SUCCESS PATH (Author Write -> Publish -> Community Comment)
POST /api/auth/login/ {username: "talha_author", password: "***"}
SELECT * FROM authentication_user WHERE username='talha_author'
User record (role='author', password_hash)
HTTP 200 OK {access: "eyJ...", refresh: "eyJ...", role: "author"}
Client persists JWT in localStorage & configures Axios headers
POST /api/posts/ [Bearer JWT] (Draft: Raft Consensus)
Verify JWT signature & extract user_id
Valid token (user_id=2, role='author')
INSERT INTO posts_post (title, slug, status='draft', author_id=2)
Saved record (id=10, status='draft')
HTTP 201 Created {id: 10, slug: "raft-consensus", status: "draft"}
POST /api/posts/10/publish/ [Bearer JWT]
Check ownership (request.user.id == post.author_id)
Permission Granted
UPDATE posts_post SET status='published', published_at=NOW() WHERE id=10
Row updated (1 row affected)
HTTP 200 OK {id: 10, status: "published", published_at: "2026-10-18T..."}
Post is now live on the public feed for all readers!
POST /api/comments/ [Bearer JWT] {post: 10, content: "Great breakdown!"}
SELECT status FROM posts_post WHERE id=10
status='published' (validation passed)
INSERT INTO comments_comment (post_id=10, author_id=2, content="...")
Saved comment (id=42, created_at=NOW())
HTTP 201 Created {id: 42, content: "...", author: {id: 2, username: "talha_author"}}
PART 2: COMPLETE FAILURE PATHS & SECURITY GUARDS
POST /api/comments/ [Bearer JWT] {post: 99, content: "Sneak preview"}
SELECT status FROM posts_post WHERE id=99
status='draft'
Validation Rule: Comments rejected on unpublished drafts
HTTP 400 Bad Request {"detail": "Cannot add comments to unpublished draft posts."}
PATCH /api/posts/10/ [Sara JWT] {title: "Malicious Edit by Peer"}
Evaluate IsAuthorOrAdminOrReadOnly (sara_writer != talha_author)
Permission Denied (Not Owner & Not Admin)
HTTP 403 Forbidden {"detail": "You do not have permission to perform this action."}
GET /api/posts/secret-draft/ [Anonymous]
SELECT * FROM posts_post WHERE slug='secret-draft' AND status='published'
Empty Result (Draft hidden by PostViewSet queryset filter)
HTTP 404 Not Found {"detail": "No Post matches the given query."}